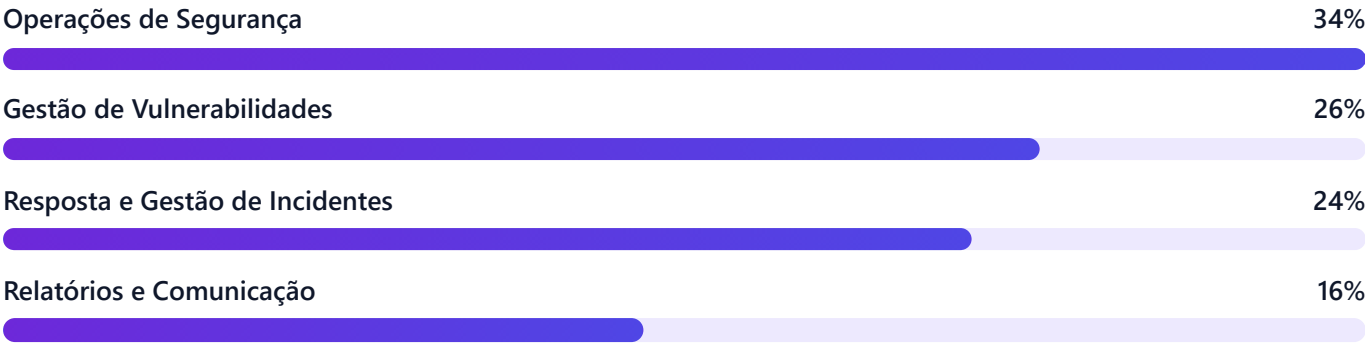
Strecht Simulados

Resumo de bolso CompTIA CySA+

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

510	6	83%
questões no curso	provas completas	nota de corte

Como é a prova CompTIA CySA+



Material independente de preparação, sem afiliação ou endosso de CompTIA. As questões são inéditas e não reproduzem a prova real.

Pronto para o exame CompTIA CySA+?

Treine com as 510 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Resposta e Gestão de Incidentes

- Desligar ou manter sob observação é escolha de contenção.
- Falso positivo se prova com contexto, como a mudança aprovada.
- Uma crise, um líder.
- Falso positivo confirmado: feche com justificativa e ajuste a regra.
- Alerta chegou: detecção. Alerta investigado e validado: análise.
- Plano diz quem e por quê; playbook diz o que fazer passo a passo.
- Verificação: procure o mesmo artefato além dos casos conhecidos.
- Sem incidente, montando o terreno: preparação.

Relatórios e Comunicação

- Relatório de vulnerabilidade é mapa do tesouro: trate como confidencial.
- Mesma ameaça, dois relatórios: tático para o SOC, estratégico para a diretoria.
- Sem patch, o item fica aberto com mitigação documentada.
- Controle parcialmente atendido é lacuna de conformidade.
- Contrato impede de corrigir sozinho: inibidor contratual, aciona o fornecedor.
- Handover: escrito no caso e confirmado de viva voz.
- Alerta que ninguém consegue olhar é ruído, não detecção.
- Tempo de resposta: da detecção à primeira ação.

Operações de Segurança

- Cortar um host da rede pelo console e seguir investigando = isolamento do EDR.
- Ativos espalhados por quilômetros e telemetria: SCADA.
- YAML usa recuo por espaços e chave e valor; nada de tabulação nem tags.
- Endpoint fora do escritório ainda precisa de política central e relatório de conformidade.
- No EVE JSON, event_type diz se o registro é alert, dns, http, flow e assim por diante.
- Saída 150 vezes maior que o normal para nuvem desconhecida: exfiltração até prova em contrário.
- CEO em webmail pedindo cartão-presente em segredo: BEC.
- GPU em região nunca usada e conta estourando: cryptomining.

Gestão de Vulnerabilidades

- CVSS = quão grave; EPSS = quão provável; contexto = quanto importa para você.

- AV:L + PR:H = o atacante já precisa estar dentro e com poder.
- Relatório de varredura é mapa do tesouro: trate como confidencial.
- Remoto entrou na página: RFI. Local vazou: LFI.
- ISO 27000 diz o que gerir; CIS diz como configurar.
- Não cabe agente? Varra pela rede.
- Equipamento que vive fora da rede pede agente.
- KEV = já explorada; Known em ransomware = mais urgente ainda.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Operações de Segurança

Um SOC usa várias ferramentas que não se comunicam de forma nativa e quer estender a plataforma de orquestração para acionar ações em um produto de EDR específico ao receber um alerta. Qual mecanismo de integração adiciona essa capacidade sem trocar a plataforma inteira?

A. Um aumento do tempo de retenção dos alertas no armazenamento central da equipe
B. Um plug-in que conecta a plataforma de orquestração ao produto de EDR específico
C. Uma reinstalação completa da plataforma de orquestração em um servidor novo e maior
D. Uma planilha compartilhada com a lista das ações que devem ser executadas à mão

Questão 2 · Gestão de Vulnerabilidades

Num teste autorizado do portal de uma distribuidora, o Burp Suite mostra a requisição "GET /download.php?arquivo=../../../../etc/passwd" e a resposta HTTP 200 contendo "root:x:0:0:root:/root:/bin/bash". Qual é a interpretação correta?

A. O parâmetro permite incluir arquivos de um servidor remoto controlado pelo atacante, caracterizando RFI
B. O parâmetro permite executar consultas SQL no banco, e o retorno mostra a tabela de usuários do banco
C. O parâmetro permite injetar scripts no navegador, e o retorno mostra o script refletido na resposta
D. O parâmetro permite ler arquivos locais do servidor fora da pasta prevista, caracterizando path traversal

Questão 3 · Operações de Segurança

A equipe de caça a ameaças de uma empresa de SaaS quer uma regra YARA que marque um arquivo quando ele contiver as duas strings declaradas, PingSleep e 203.0.113.9, ao mesmo tempo. Qual condição expressa esse requisito?

A. condition: 1 of them
B. condition: any of them
C. condition: none of them
D. condition: all of them

Questão 4 · Gestão de Vulnerabilidades

A varredura interna de uma universidade aponta SMBv1 habilitado no servidor 10.50.2.10, mas a varredura externa contra o IP público que faz NAT para esse servidor não mostra a porta 445. Qual é a interpretação correta?

A. O NAT desabilitou o protocolo SMBv1 no servidor, e a varredura interna não percebeu essa mudança no host
B. O perímetro bloqueia a 445 vinda da internet, mas a falha continua alcançável por quem está na rede interna
C. O servidor corrigiu o SMBv1 entre as duas varreduras, e a varredura interna mostrou um resultado antigo do cache
D. O achado interno é falso, porque a varredura externa é a referência mais confiável do ambiente

Questão 5 · Gestão de Vulnerabilidades

Um painel interno de uma transportadora recebe o nome de um relatório em um parâmetro e o repassa a um comando do sistema operacional para gerar o PDF. O teste confirmou injeção de comandos com o uso de ponto e vírgula. Além de evitar chamar o shell, qual prática de codificação segura trata melhor a entrada?

A. Remover do parâmetro o caractere ponto e vírgula encontrado, mantendo os demais caracteres
B. Validar o parâmetro no servidor com uma lista de permissões dos nomes de relatório aceitos
C. Validar o parâmetro no navegador com JavaScript, bloqueando caracteres especiais no formulário
D. Codificar a saída do relatório em HTML para que o conteúdo não seja interpretado pelo navegador

Questão 6 · Operações de Segurança

Em uma filial de uma rede de lojas, estações passaram a receber endereços 192.168.50.x com gateway e DNS 192.168.50.1, entregues pelo servidor DHCP 192.168.50.1. O DHCP oficial é 10.40.0.5 e distribui a faixa 10.40.x. Logo depois, usuários relatam alertas de certificado ao acessar sites. Qual é a interpretação e o controle mais adequados?

A. Servidor DHCP rogue entregando gateway e DNS falsos; ativar DHCP snooping nos switches
B. Conflito de IP entre estações; habilitar a detecção de conflito no servidor oficial
C. Falha do relay DHCP no roteador; reiniciar o serviço de encaminhamento da filial
D. Esgotamento do escopo DHCP oficial; ampliar a faixa 10.40.x no servidor da filial

Questão 7 · Operações de Segurança

Um analista de um banco recupera de um host comprometido um bloco de configuração ofuscado; no hexadecimal, o mesmo byte 5a se repete onde o formato original teria sequências de zeros, indício clássico de XOR com chave de um byte. Qual operação do CyberChef ajuda a recuperar o texto claro sem conhecer a chave?

A. A operação XOR Brute Force, que testa chaves de um byte e mostra as saídas candidatas
B. A operação Gunzip, que descomprime fluxos de dados gravados no formato de compressão gzip
C. A operação From Base64, que decodifica dados que foram representados no formato Base64
D. A operação To Hex, que converte os bytes para a sua representação em hexadecimal

Questão 8 · Operações de Segurança

Um analista de uma distribuidora de energia quer criar no SIEM uma busca por criações de processo em que o pai é o WINWORD.EXE e o filho é o powershell.exe ou o wscript.exe, padrão comum de macro maliciosa. Qual evento do log de segurança do Windows traz o processo criado e o processo que o criou?

A. O evento 4624, logon bem-sucedido, com o tipo de logon e a conta autenticada
B. O evento 5140, acesso a compartilhamento de rede, com o nome do compartilhamento
C. O evento 4688, criação de processo, com o novo processo e o processo criador
D. O evento 4634, logoff de conta, com o encerramento da sessão de logon da conta

Questão 9 · Operações de Segurança

Uma rede de clínicas com 40 filiais e 300 funcionários remotos envia todo o tráfego de internet para o firewall do data center da matriz, o que gera latência e não protege bem o acesso a aplicações SaaS. A diretoria quer um modelo único de rede e segurança entregue pela nuvem. Qual arquitetura atende a esse objetivo?

A. NAC, validando a postura dos dispositivos antes da conexão às portas das filiais
B. MPLS, substituindo a internet das filiais por enlaces privados até a matriz da rede
C. SASE, unindo SD-WAN e serviços como SWG, CASB, FWaaS e ZTNA entregues pela nuvem
D. SIEM, centralizando os logs das filiais para correlacionar os eventos de navegação

Questão 10 · Relatórios e Comunicação

O gráfico de tendência de uma empresa de call center mostra que as mesmas vulnerabilidades do navegador reaparecem nas estações algumas semanas depois de corrigidas, logo após a recriação das máquinas a partir da imagem padrão. Qual conclusão o relatório deve registrar?

A. Ataque em andamento, em que um invasor reinstala versões vulneráveis do navegador
B. Imagem padrão desatualizada, que reintroduz as falhas e precisa entrar no plano de correção
C. Comportamento normal, que pode ser desconsiderado porque as falhas já foram corrigidas
D. Falha do scanner, que mantém em cache os resultados das varreduras antigas das estações

Gabarito comentado

1. B) Um plug-in que conecta a plataforma de orquestração ao produto de EDR específico
Estender a orquestração para falar com um produto específico = plug-in.

2. D) O parâmetro permite ler arquivos locais do servidor fora da pasta prevista, caracterizando path traversal
../ com /etc/passwd na resposta: arquivo local exposto.

3. D) condition: all of them
YARA: all of them exige todas as strings; any of them basta uma.

4. B) O perímetro bloqueia a 445 vinda da internet, mas a falha continua alcançável por quem está na rede interna
Fechado por fora não quer dizer seguro por dentro.

5. B) Validar o parâmetro no servidor com uma lista de permissões dos nomes de relatório aceitos
Valide no servidor com lista do que é permitido, não do que é proibido.

6. A) Servidor DHCP rogue entregando gateway e DNS falsos; ativar DHCP snooping nos switches
Gateway estranho entregue por DHCP desconhecido: DHCP rogue; a defesa é DHCP snooping.

7. A) A operação XOR Brute Force, que testa chaves de um byte e mostra as saídas candidatas
Byte repetido no lugar dos zeros sugere XOR de um byte: XOR Brute Force no CyberChef.

8. C) O evento 4688, criação de processo, com o novo processo e o processo criador
Processo pai e filho no log de segurança do Windows: evento 4688.

9. C) SASE, unindo SD-WAN e serviços como SWG, CASB, FWaaS e ZTNA entregues pela nuvem
Rede e segurança como serviço na nuvem, perto do usuário: SASE.

10. B) Imagem padrão desatualizada, que reintroduz as falhas e precisa entrar no plano de correção
Vulnerabilidade que volta sempre: corrija a origem, não a máquina.

Pronto para o exame CompTIA CySA+?

Treine com as 510 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →